Annexe - RGPD & RGAA : protection des données et accessibilité numérique

1) Introduction : pourquoi ces deux sujets sont essentiels pour un développeur web

Lorsqu'on conçoit des sites web ou des applications, on ne se limite pas à l'aspect esthétique ou fonctionnel. On est également responsable de **ce que l'on collecte**, **comment on le traite**, et **comment on rend les contenus utilisables par tous**, y compris les personnes ayant un handicap.

Le **RGPD** (Règlement général sur la protection des données) s'impose pour tout traitement de données personnelles dans l'UE, visant à préserver la vie privée. Le **RGAA** (Référentiel général d'amélioration de l'accessibilité) impose des règles pour rendre les contenus numériques accessibles dans le contexte français, notamment pour les services publics. Les deux sont des obligations légales dans de nombreux cas, et leur non-respect peut entraîner des sanctions ou des conséquences graves (juridiques, réputation, exclusion d'utilisateurs).

Dans cette annexe, nous verrons :

1. Le cadre légal et les principes fondamentaux du RGPD.
2. Les obligations concrètes pour un site ou une application web.
3. Le cadre légal du RGAA et ses critères d'accessibilité.
4. Des bonnes pratiques de mise en conformité pour les développeurs.
5. Un exercice pratique pour appliquer ces concepts.

2) Le RGPD : cadre légal, principes et obligations

2.1 Qu'est-ce que le RGPD ?

Le **RGPD** (*Règlement (UE) 2016/679*) est un texte européen entré en application le 25 mai 2018 dans tous les États membres de l'UE. (EUR-Lex)
Il remplace la directive 95/46/CE (loi "vie privée"). Son objectif : harmoniser la législation sur la protection des données à caractère personnel à l'échelle européenne. (CNIL

La **CNIL** (en France) est l'autorité de contrôle qui veille au respect du RGPD sur le territoire national. (CNIL

Textes de référence

- Texte officiel du RGPD (version consolidée) : EUR-Lex / Regulation 2016/679
- Version accessible / commentée : gdpr-info.eu
- CNIL : explications du RGPD pour les personnes et les professionnels : CNIL – RGPD
- Loi française relative à la protection des données personnelles (complément national) : Loi n° 2018-493 du 20 juin 2018 (Légifrance)

2.2 Principes fondamentaux du RGPD

Le RGPD repose sur plusieurs **principes de protection** que tout traitement de données doit respecter :

1. **Licéité, loyauté et transparence** : les données doivent être collectées de manière légale, dans un but clair, avec information aux personnes concernées.
2. **Limitation des finalités** : on ne peut collecter des données que pour des finalités précises, légitimes, explicitées en amont.
3. **Minimisation des données** : ne collecter que les données strictement nécessaires (pas d'excès).
4. **Exactitude** : les données doivent être à jour. On doit pouvoir corriger ou effacer si nécessaire.
5. **Limitation de la conservation** : les données ne doivent pas être conservées plus longtemps que nécessaire (durées définies selon les cas).
6. **Intégrité et confidentialité** : les données doivent être sécurisées (limiter les accès, utiliser le chiffrement si pertinent).
7. **Responsabilité (accountability)** : le responsable du traitement doit pouvoir démontrer qu'il respecte ces principes (tenue de registres, documentation).

Tout manquement à ces principes est risqué, et l'autorité de contrôle peut exiger des actions correctrices voire appliquer des sanctions. (INAMI)

2.3 Les droits des personnes concernées

L'une des pierres angulaires du RGPD, c'est le **droit des individus sur leurs données**. Voici les principaux :

- **Droit d'accès** : la personne peut demander quelles données sont traitées la concernant, et obtenir une copie.
- **Droit de rectification** : rectifier des données inexactes.
- **Droit à l'effacement (droit à l'oubli)** : demander la suppression des données dans certains cas.
- **Droit à la limitation du traitement** : demander que les données ne soient pas traitées pendant un certain temps.
- **Droit à la portabilité** : obtenir ses données dans un format structuré et réutilisable (ex. JSON, CSV) et les transférer à un autre responsable de traitement si cela est techniquement possible.
- **Droit d'opposition** : s'opposer à un traitement (par exemple marketing), sauf motifs légitimes impérieux.
- **Droit de retirer le consentement** : s'il est utilisé comme base légale, on doit pouvoir le retirer aussi facilement qu'on l'a donné.
- **Droit de ne pas faire l'objet d'une décision automatique** fondée uniquement sur un traitement automatisé, dans certains contextes (y compris profilage).

2.4 Bases légales du traitement de données

Pour que le traitement soit légal, il doit reposer sur l'une des bases suivantes :

- **Consentement explicite** de la personne (ex. formulaire clair, case à cocher non pré-cochée).
- **Exécution d'un contrat** (ex. données nécessaires à la fourniture d'un service).
- **Obligation légale** (ex. obligations fiscales, comptabilité).
- **Intérêt vital** (ex. données médicales en urgence).

- **Mission d’intérêt public** (dans un contexte public ou de service public).
- **Juste intérêt légitime** (équilibrer les intérêts du responsable et les droits des individus) – à utiliser avec précaution et documenter l’analyse.

2.5 Obligations du responsable de traitement et du sous-traitant

Le responsable de traitement

C’est l’entité (personne physique ou morale) qui décide pourquoi et comment les données sont traitées. Ses obligations :

- Informer les personnes (politique de confidentialité, mentions légales).
- Mettre en place des mesures techniques et organisationnelles pour sécuriser les données (authentification, chiffrement, anonymisation le cas échéant).
- Tenir un **registre des traitements** (qui, quoi, pourquoi, durée, destinataires).
- Réaliser une **analyse d’impact sur la protection des données** (PIA / DPIA) quand le traitement présente un risque élevé pour les droits.
- Notifier les violations de données (data breach) à l’autorité de contrôle (en France, la CNIL) dans les 72 heures, sauf cas mineurs.
- Vérifier les sous-traitants : ils doivent respecter le RGPD aussi, via des contrats spécifiques.
- Respecter la vie privée dès la conception (*privacy by design*) et par défaut (*privacy by default*).

Le sous-traitant

Le sous-traitant traite les données pour le compte du responsable. Ses obligations :

- Ne traiter les données que selon les instructions du responsable.
- Mettre en œuvre des mesures de sécurité.
- Aider le responsable à répondre aux droits des personnes (accès, suppression…).
- Informer immédiatement le responsable en cas de violation.
- N'engager aucun autre sous-traitant sans accord préalable du responsable.

2.6 Sanctions et risques juridiques

Le RGPD prévoit des sanctions pouvant aller jusqu'à **20 millions d'euros** ou **4 % du chiffre d'affaires annuel mondial**, selon le montant le plus élevé.

En outre :

- Des mesures correctrices peuvent être imposées (suspension du traitement, limitation…).
- La réputation peut être fortement impactée : perte de confiance des utilisateurs.
- Des actions de groupe ou recours individuels sont possibles dans certains pays.

3) Le RGAA : accessibilité numérique en France

3.1 Qu'est-ce que le RGAA ?

Le **Référentiel général d'amélioration de l'accessibilité (RGAA)** est le document de référence français qui définit les critères à respecter pour rendre les sites et services numériques accessibles aux personnes handicapées. (Accessibilité Numérique)

Il s'appuie sur les normes internationales WCAG (*Web Content Accessibility Guidelines*) mais l'adapte au contexte français (édité par la DINUM, Direction interministérielle du numérique). (info.gouv.fr)

La version officielle récente est le **RGAA 4.0** (et des mises à jour évolutives sont prévues).

Textes de référence

- Site officiel de l'accessibilité numérique (avec le RGAA, ses mises à jour, guides, critères) : accessibilite.numerique.gouv.fr
- Contexte juridique et obligations en France : Info.gouv – accessibilité

3.2 Obligations légales en France

En France, l'accessibilité numérique est non seulement une bonne pratique, mais souvent une **obligation légale**, surtout pour les sites publics ou les démarches en ligne :

- Le **décret du 24 juillet 2019** fixe les obligations de mise en accessibilité dans le temps pour les services de l'État, des collectivités et certains sites privés. (Access42
- Les services concernés doivent publier une **déclaration de conformité** et rendre publique la date prévue de mise en conformité.

- Les critères techniques du RGAA couvrent des aspects éditoriaux, d'ergonomie, de compatibilité avec les aides techniques, etc. Le référentiel compte **106 critères** répartis en 13 thématiques. (Accessibilité Numérique

- En cas de non-conformité, des contrôles peuvent être menés par l'**Arcom** (ex-CSA / HADOPI) ou d'autres autorités, et des sanctions (amendes administratives) sont prévues.

3.3 Principaux critères du RGAA (exemples)

Voici quelques critères illustratifs pour mieux comprendre ce que demande le RGAA (et comment l'appliquer) :

- Chaque **iframe** doit avoir un attribut `title` pertinent (critère 2.1) pour que les technologies d'assistance identifient le contenu embarqué.

- L'information ne doit pas dépendre uniquement de la couleur : un lien rouge ne doit pas signifier "danger" sans repère textuel ou visuel complémentaire. (critère 3.1)

- Pour les médias (audio, vidéo), des sous-titres, des transcriptions, des alternatives textuelles ou des contrôles accessibles doivent être fournis (critère 4.13)

- Les tableaux complexes doivent avoir des en-têtes (`<th>`), des attributs `scope` ou `headers` pour relier les cellules aux en-têtes, et être compréhensibles en mode linéarisé (critères dans la thématique Tableaux)

- Le document doit structurer l'information à travers des titres (`<h1>` , `<h2>` , etc.) pertinents et correctement hiérarchisés (critère de structuration)

- Quand les feuilles de style sont désactivées, l'information essentielle doit rester visible et compréhensible (critère dans « Présentation de l'information »)

- Le texte doit rester lisible lorsque la taille est augmentée jusqu'à 200 % (critère 10.4)

Ces critères ne sont qu'un échantillon : pour être conforme, il faut vérifier **tous les critères applicables** selon contextes et niveaux d'exigence.

3.4 RGAA vs WCAG

Le RGAA s'appuie sur les **WCAG 2.1** (norme internationale d'accessibilité), mais les traduit dans le contexte français (terminologie, exigences, modalités de test). Le RGAA ajoute aussi des adaptations nationales ou des critères spécifiques pour l'environnement administratif. (info.gouv.fr)

Dans les développements, il est recommandé de se référer aux deux : utiliser les recommandations WCAG pour la compréhension théorique (via MDN, W3C), et appliquer les critères RGAA pour la conformité en France.

4) Bonnes pratiques de mise en conformité pour les développeurs

Voici des conseils concrets pour intégrer le RGPD et le RGAA dès la conception (plutôt que de les ajouter après coup) :

4.1 Intégrer le RGPD dès la conception (*privacy by design*)

- Choisir d'emblée de ne pas collecter de données personnelles superflues.
- Masquer ou ne pas activer automatiquement les fonctionnalités de tracking (cookies, analytics) : le consentement doit être explicite.
- Mettre en place un **outil de gestion de consentement** (Consent Management Platform, CMP) pour que l'utilisateur puisse accepter, refuser, ou retirer son consentement.
- Anonymiser les données si possible (par exemple utiliser un identifiant non tracé).
- Chiffrer les données sensibles (mot de passe, adresse, etc.) en base ou en transit (HTTPS obligatoire).
- Prévoir la possibilité de supprimer ou anonymiser les données sur demande.

4.2 Pratiques accessibles et conformes RGAA

- Toujours fournir un texte alternatif pertinent (`alt`) pour les images informatives, et `alt=""` pour les images décoratives.
- Utiliser des balises sémantiques (`<header>` , `<nav>` , `<main>` , `<article>` , `<section>`) pour exposer la structure aux technologies d'assistance.
- Fournir des labels correctement associés aux champs de formulaire (avec `for` / `id`).
- Ajouter des légendes, descriptions ou instructions quand c'est utile.
- Vérifier le contraste de couleurs (foreground / background) selon les contraintes RGAA / WCAG.

- Prévoir un ordre de tabulation logique (via `tabindex` seulement si nécessaire) pour permettre la navigation au clavier.
- S’assurer que les contenus dynamiques (modaux, alertes, zones mises à jour) notifient les technologies d’assistance via ARIA ou via DOM (ex. `aria-live`).
- Tester l’interface avec des lecteurs d’écran (NVDA, VoiceOver) et des outils d’audit d’accessibilité.
- Vérifier la conformité avec le RGAA (outil d’audit, liste de contrôle complète).
- Conserver une **version accessible** d’un document (PDF, etc.) s’il est fourni.

5) Exemple de mise en conformité duale (RGPD + RGAA) : contact utilisateur

Imaginons que tu ajoutes un formulaire de contact sur un site. Voici un exemple de bonne mise en œuvre :

```html
<form action="/contact" method="post" novalidate>
  <fieldset>
    <legend>Formulaire de contact</legend>
    <div>
      <label for="nom">Nom</label>
      <input type="text" id="nom" name="nom" required aria-required="true">
    </div>
    <div>
      <label for="email">Courriel</label>
      <input type="email" id="email" name="email" required aria-required="true">
    </div>
    <div>
      <label for="message">Message</label>
      <textarea id="message" name="message" rows="5" required aria-required="true">
</textarea>
    </div>
    <div>
      <input
        type="checkbox"
        id="consentement"
        name="consentement"
        required
        aria-required="true"
      >
      <label for="consentement">
        J’accepte que mes données soient utilisées pour me recontacter. (vous pouvez
retirer votre consentement à tout moment)
      </label>
    </div>
    <button type="submit">Envoyer</button>
  </fieldset>
</form>
```

Explications RGPD / RGAA :

- Le champ **consentement** est clairement séparé des autres champs et ne doit pas être pré-coché (le consentement doit être actif).
- Il faut expliquer **dans une politique de confidentialité** pourquoi sont collectés `nom`, `email`, `message`, comment ces données seront utilisées, conservées, et les droits de la personne (droit d’accès, suppression, retrait).
- Le formulaire est accessible : chaque champ a un `label` clairement lié (`for` / `id`), ce qui permet aux lecteurs d’écran de comprendre.

- L’information relative au consentement doit être clairement lisible (texte non confondu par la couleur seule).
- Lorsque l’utilisateur soumet, il faut stocker les données de manière sécurisée. Si un historique est conservé, il faut pouvoir supprimer les données sur demande.
- Si une personne demande à voir ses données ou à les effacer, il faut pouvoir le faire.
- Par défaut, il ne faut pas activer des cookies de tracking ou analytics sans consentement préalable.